

BUUPP

Mesures de sécurité et de protection des données personnelles

Dossier de conformité RGPD — à présenter en cas de contrôle (CNIL ou autre autorité)

Responsable de traitement : Majelink (éditeur de la plateforme BUUPP) — RCS Pau 892 514 167 — 12
Impasse des Étriers, 64140 Lons

Chargé à la protection des données : dp.buupp@buupp.com

Version : 14/06/2026

Document de travail ancré sur le système en production (politique de confidentialité publiée, base de données, code source). Les arbitrages juridiques (bases légales, durées, désignation du DPO) doivent être validés par le DPO / le conseil juridique. Les champs marqués « [À COMPLÉTER] » requièrent une décision du responsable de traitement. Ce document ne constitue pas un avis juridique.

0. Objet du document

BUUPP est une plateforme française de mise en relation rémunérée à double consentement entre particuliers (« prospects ») et professionnels. Les particuliers acceptent, sollicitation par sollicitation, d'être contactés en échange d'une rémunération ; aucune donnée n'est transmise sans accord explicite.

Ce document recense les mesures techniques et organisationnelles de sécurité et de protection des données, et indique où les vérifier dans le système (fichier de code, migration, configuration).

Principe directeur : protection des données dès la conception (privacy by design) et par défaut. Expertise RGPD portée par le fondateur, juriste spécialisé en protection des données personnelles.

1. Pseudonymisation et minimisation

Les données prospect sont stockées en base mais jamais transmises telles quelles : la transformation est appliquée à la lecture, côté serveur.

- nom → masquage ; e-mail → alias watermarqué ; date de naissance → tranche d'âge de 5 ans ; code postal → département ; adresse/poste/revenus → suppression ; véhicule/animaux/foyer → catégorisation.
- Seul BUUPP peut relier un profil pseudonymisé à la personne (réversible par buupp seul).

Preuve : lib/pro/pseudonymize.ts ; app/api/pro/contacts/[relationId]/details/route.ts ; minimisation par finalité (page /minimisation).

2. Consentement (double consentement)

Deux consentements explicites : (1) acceptation des CGU à l'inscription, (2) acceptation explicite de chaque sollicitation. Chaque accord est limité à une seule sollicitation — pas de réutilisation ni de revente.

Preuve : lib/cnil/consent.ts ; CGU /cgu, /cgv.

3. Sécurité technique

- **Hébergement UE** — Supabase (PostgreSQL) en Irlande (eu-west-1) ; application sur Vercel.
- **Chiffrement** — TLS en transit, chiffrement au repos (Supabase).
- **Authentification** — Clerk + middleware (proxy.ts) ; aucune donnée prospect accessible sans authentification.
- **Cloisonnement (RLS)** — Row Level Security ; tables d'audit sans policy (service_role uniquement).
- **Rate-limiting** — endpoints publics/sensibles (lib/rate-limit/check.ts).
- **Paielements** — délégués à Stripe Connect (PCI-DSS) ; aucune donnée carte stockée par BUUPP.

4. Anti-fraude multicouche

Mesure publique : « Contraintes d'unicité IBAN / téléphone / rôle, honeypots sur formulaires publics, journal d'audit verrouillé des révélations. » Démonstration :

- **Unicité IBAN** — index UNIQUE (20260507150000_prospect_rib_unique_iban.sql).
- **Unicité téléphone** — index UNIQUE partiel + OTP (20260507160000_... ; 20260505070000_phone_verification.sql).
- **Exclusivité de rôle** — trigger 23505 (20260508140000_role_exclusivity.sql).
- **Honeypots** — champ caché « website » (ContactDpoForm.tsx, HomeContactSection.tsx, /api/waitlist).
- **Watermarking** — alias e-mail unique par relation routé via Cloudflare (lib/aliases/relation-email.ts).
- **Journal verrouillé** — cf. section 5.

5. Journalisation et traçabilité des accès

Toute révélation (e-mail, téléphone, nom, fiche détaillée) par un pro est journalisée dans `pro_contact_reveals` : qui / quoi / quel prospect / quand.

- **Exhaustivité (fail-closed)** — la donnée n'est livrée que si la révélation est journalisée ; sinon HTTP 500, rien n'est exposé.
- **Inviolabilité (append-only)** — trigger anti-UPDATE appliqué en prod (`pro_contact_reveals_lock_update`).
- **Conservation** — 24 mois puis purge quotidienne (`lib/pro/reveals-retention.ts`).

Autres journaux : clics de contact (`pro_contact_clicks` + alerte abus) ; événements administrateur (`admin_events`).

6. Droits des personnes

- Accès (art. 15) : le prospect peut savoir qui a accédé à ses données et quand.
- Rectification (16) / effacement (17) : depuis l'espace prospect ou via le DPO ; l'effacement supprime données et journaux liés (cascade).
- Transparence : politique RGPD, page DPO, information cookies.

7. Sous-traitants et hébergeurs

Sous-traitant	Rôle	Localisation	Encadrement
Supabase Inc.	Base de données PostgreSQL + Storage	UE — Irlande (eu-west-1)	Art. 28 — DPA
Vercel Inc.	Hébergement de l'application	États-Unis (servi en UE)	SCC (clauses types)
Clerk Inc.	Authentification / identités	États-Unis	SCC (clauses types)
Stripe Payments Europe Ltd	Paielements, KYC, virements (Connect)	UE — Irlande	RT distinct (PCI-DSS)
Brevo (Sendinblue SAS)	E-mails et SMS transactionnels	UE — France	Art. 28 — DPA
Cloudflare	Routage des alias e-mail watermarqués	Réseau mondial (UE)	SCC (clauses types)
DGFIP	Transmission fiscale annuelle (DAC7)	France	Destinataire légal

8. Synthèse — mesure → preuve

Mesure	Mise en œuvre	Emplacement (preuve)
Pseudonymisation à la lecture	Masquage/généralisation/suppression côté serveur	<code>lib/pro/pseudonymize.ts</code>
E-mail watermarqué	Alias unique par relation	<code>lib/aliases/relation-email.ts</code>
Unicité IBAN/téléphone/rôle	Index UNIQUE + trigger 23505	<code>migrations 2026050715/16/08...</code>
Honeypots	Champ caché 'website'	<code>ContactDpoForm.tsx</code> ; <code>HomeContactSection.tsx</code>
Journal des révélations	qui/quoi/quand	table <code>pro_contact_reveals</code>
Audit fail-closed	Pas de journal → pas de révélation	<code>.../reveal details group-reveal</code>
Journal append-only	Trigger anti-UPDATE	<code>20260718120000_..._append_only.sql</code>
Rétention 24 mois	Purge quotidienne	<code>lib/pro/reveals-retention.ts</code>
RLS / Rate-limit / Auth	<code>service_role</code> only ; limites ; Clerk	<code>proxy.ts</code> ; <code>lib/rate-limit/check.ts</code>